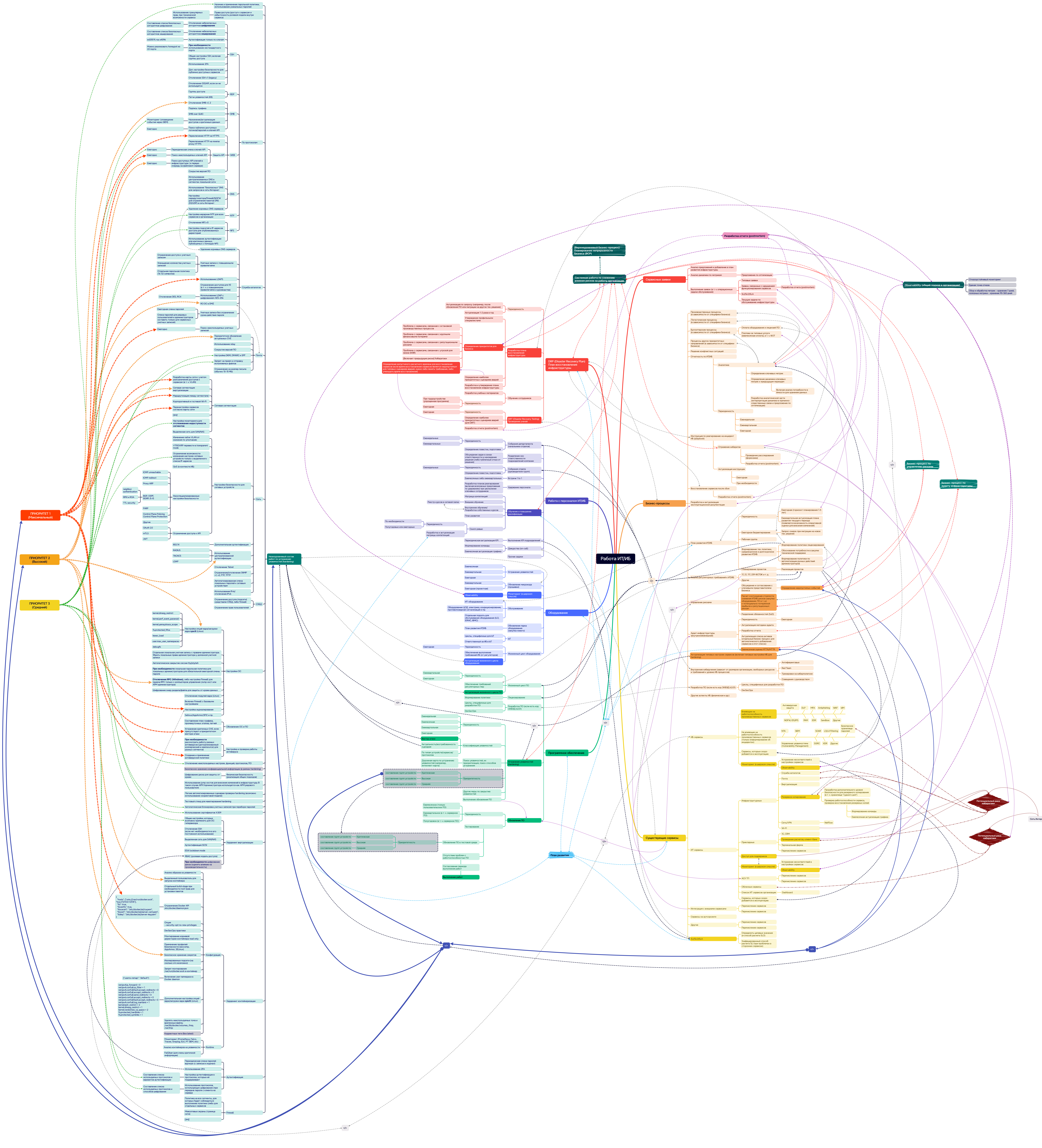

Работа ИТ/ИБ

- ПРИОРИТЕТ 1 (Максимальный)
- ПРИОРИТЕТ 2 (Высокий)
- ПРИОРИТЕТ 3 (Средний)

Низкоуровневый состав работ по устранению уязвимостей (hardening)

- Наличие и применение парольной политики, использование уникальных паролей
- Права доступа (доступ к сервисам и избыточность ролевой модели внутри сервиса)
  - Использование гранулярных прав, при технической возможности сервиса
- По протоколам
  - SSH
    - Отключение небезопасных алгоритмов **шифрования**
      - Составление списка безопасных алгоритмов шифрования
    - Отключение небезопасных алгоритмов **хеширования**
      - Составление списка безопасных алгоритмов хеширования
    - Аутентификация только по ключам
      - ed25519, rsa ≥4096
    - **При необходимости** использование нестандартного порта
      - Можно реализовать honeypot из 22 порта
    - Общие настройки SSH, включая группы доступа
    - Использование 2FA
    - Доп. настройки безопасности для публично доступных сервисов
    - Отключение SSH v1 (legacy)
    - Отключение GSSAPI, если он не используется
  - RDP
    - Группы доступа
    - Патчи уязвимостей (KB)
  - SMB
    - Отключение SMB v1, 2
    - Подпись трафика
    - SMB over QUIC
    - Назначение/актуализация доступов к критичным данным
      - Мониторинг (оповещение события через SIEM)
    - Поиск публично доступных логинов/паролей и ключей API
      - Ежегодно
  - WEB
    - Переключение HTTP на HTTPS
    - Переключение HTTP на reverse proxy HTTPS
    - Защита API
      - Периодическая смена ключей API
        - Ежегодно
      - Поиск неиспользуемых ключей API
        - Ежегодно
      - Поиск доступных API ключей в инфраструктуре (в первую очередь на файловом сервере)
        - Ежегодно
    - Сокрытие версий ПО
  - DNS
    - Использование централизованных DNS в сегментах локальной сети
    - Использование "безопасных" DNS для запросов в сеть Интернет
    - Настройка маршрутизатора/firewall/NGFW для ограничения пакетов DNS (53/UDP) в сеть Интернет
    - Удаление корневых DNS серверов
  - NTP
    - Настройка иерархии NTP для всех сервисов в организации
  - NFS
    - Отключение NFS v3
    - Настройка подсетей и IP-адресов доступа для опубликованных директорий
    - Использование аутентификации для критичных данных, публикуемых с помощью NFS
- Служба каталогов
  - Удаление корневых DNS серверов
  - Учетные записи с повышенными привилегиями
    - Ограничение доступа к учетным записям
    - Уменьшение количества учетных записей
    - Отдельная парольная политика (16-32 символов)
  - Использование LDAPS
  - Ограничение доступов для УЗ (в т. ч. с повышенными привилегиями и руководства)
  - Использование LDAP с шифрованием AES-256
    - Отключение DES, RC4
  - RO DC в DMZ
  - Учетные записи без ограничения срока действия пароля
    - Ежегодная смена паролей
    - Смена паролей для рядовых пользователей и администраторов (оставить только для сервисных учетных записей)
  - Поиск неиспользуемых учетных записей
    - Ежегодно
- Почта
  - Приоритетное обновление актуальных CVE
  - Использование relay
  - Сокрытие версий ПО
  - Настройка DKIM, DMARC и SPF
  - Запрет на прием и отправку исполняемых файлов
  - Ограничение на размер письма (обычно 10-15 Mb)
- Сеть
  - Сетевая сегментация
    - Разработка карты сети с учетом разграничения доступов к сервисам (в т. ч. VLAN)
    - Сетевая сегментация виртуализации
    - Маршрутизация между сегментами
    - Корпоративный и гостевой Wi-Fi
    - Перенастройка сервисов согласно карты сети
    - DMZ
    - Настройка мониторинга для **отслеживания недоступности сегментов**
    - Выделенная сеть для SAN/NAS
  - Настройки безопасности для сетевых устройств
    - Изменение native VLAN от значения по умолчанию
    - VTP/GVRP перевести в transparent mode
    - Ограничение возможности изменения настроек сетевых устройств только с выделенного списка IP-адресов
    - QoS (в контексте ИБ)
    - Узкоспециализированные настройки безопасности
      - ICMP unreachable
      - ICMP redirect
      - Proxy ARP
      - BGP, OSPF, EIGRP, IS-IS
        - neighbor authentication
        - RPKI и ROA
        - TTL security
      - FHRP
      - Control Plane Policing Control Plane Protection
      - Другие
    - Ограничение доступа к API
      - OAuth 2.0
      - mTLS
      - JWT
  - Дополнительная аутентификация
    - 802.1X
  - Использование централизованной аутентификации
    - RADIUS
    - TACACS
    - LDAP
  - Отключение Telnet
  - Ограничение/отключение SNMP v1, v2, FTP, TFTP
  - Автоматизированная смена локальных паролей к сетевым устройствам
  - Использование IPv6/ отключение IPv6
- СУБД
  - Ограничение доступа (подсети) средствами СУБД, либо firewall
  - Ограничение прав пользователей
- Настройки ОС
  - Настройка опций ядра/загрузки ядра **sysctl** (Linux)
    - kernel.dmesg_restrict
    - kernel.perf_event_paranoid
    - kernel.yama.ptrace_scope
    - fs.protected_fifos
    - kexec_load
    - user.max_user_namespaces
    - debugfs
  - Отдельная локальная учетная запись с правами администратора. Убрать локальные права администратора у доменной учетной записи
  - Автоматическое закрытие сессии tty/pty/ssh
  - **При необходимости** локальная парольная политика для локальных администраторов для обязательной ежегодной смены пароля
  - **Отключение RPC (Windows)**, либо настройка Firewall для приема RPC только с компьютеров управления (Jump хост или АРМ администратора)
  - Шифрование swap раздела/файла для защиты от кражи данных
  - Отключение модулей ядра (Linux)
  - Включен Firewall с базовыми настройками
  - Настройка журналирования
  - Selinux/AppArmor/ЗПС и пр.
- Обновление ОС и ПО
  - Составление план-графика, промежуточных этапов, патчей
  - Устранение критичных CVE, если присутствуют в приоритетном векторе атаки
- Настройка и проверка работы антивируса
  - **При необходимости** рассмотреть работу разных антивирусов (централизованный коммерческий и opensource) для разных сегментов
  - Создание и применение антивирусной политики
- Отключение неиспользуемых настроек, функций, протоколов, ПО
- Безопасное хранение конфиденциальной информации (в рамках hardening)
- Шифрование диска для защиты от кражи
  - Физическая безопасность (реализация общих подходов)
- Использование jump хостов для внесения изменений в инфраструктуру. В таком случае АРМ Администратора используется как АРМ рядового пользователя
- Легкие автоматизированные сценарии проверки hardening (возможно использование скоринговой модели)
- Тестовый стенд для макетирования hardening
- Автоматическая блокировка учетных записей при переборе паролей
- Использование сертификатов X.509
- Харденинг виртуализации
  - Общие настройки, которые возможно применить для ОС гипервизора
  - Отключение SSH (если нет необходимости в его постоянном использовании)
  - Выделенная сеть для SAN/NAS
  - Аутентификация iSCSI
  - ESXi lockdown mode
  - RBAC (ролевая модель доступа)
  - **При необходимости** шифрование диска (оценить влияние на производительность)
- Харденинг контейнеризации
  - Конфигурация
    - Анализ образов на уязвимости
    - Выделенный пользователь для запуска контейнера
    - Отдельный build-stage при необходимости root прав для установки пакетов
    - Ограничение Docker API /etc/docker/daemon.json

```
{
  "hosts": ["unix:///var/run/docker.sock", "tcp://127.0.0.1:2376"],
  "tls": true,
  "tlsverify": true,
  "tlscacert": "/etc/docker/ssl/ca.pem",
  "tlscert": "/etc/docker/ssl/server-cert.pem",
  "tlskey": "/etc/docker/ssl/server-key.pem"
}
```

    - Опция --security-opt no-new-privileges
    - DevSecOps практики
    - Монтирование корневой директории контейнера read only
    - Применение профилей безопасности (seccomp, AppArmor, SELinux)
    - Безопасное хранение секретов
    - Изолированные подсети (на сколько это возможно)
    - Запрет монтирования /var/run/docker.sock в контейнер
    - Включение user namespace в Docker daemon
      - {"userns-remap": "default"}
    - Дополнительная настройка опций ядра/загрузки ядра **sysctl** (Linux)

```
net.ipv4.ip_forward = 0
net.ipv4.conf.all.rp_filter = 1
net.ipv4.conf.default.accept_redirects = 0
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.all.send_redirects = 0
net.ipv6.conf.all.accept_redirects = 0
net.ipv6.conf.default.accept_redirects = 0
net.ipv4.conf.all.log_martians = 1
kernel.kptr_restrict = 2
kernel.dmesg_restrict = 1
kernel.randomize_va_space = 2
fs.protected_hardlinks = 1
fs.protected_symlinks = 1
```

    - Удалять неиспользуемые тома и временные файлы /var/lib/docker/volumes, /tmp, /var/tmp
    - Корректные теги (без latest)
  - Runtime
    - Мониторинг (Prometheus, Falco, Tracee, Graylog, ELK, PT SIEM, etc)
    - Анализ контейнеров на уязвимости
    - Fail2ban (для очень критичной информации)
- Аутентификация
  - Периодическая смена паролей вручную (с записью в журнал)
  - Использование 2FA
  - Настройка аутентификации в протоколах, которые её поддерживают
    - Составление списка используемых протоколов и вариантов аутентификации
  - Использование протоколов, использующих шифрование (при передаче пароля с клиента на сервер)
    - Составление списка используемых протоколов и способов шифрования
- Firewall
  - Политика на все сегменты, для которых будет соблюдаться выполнение политики (либо для отдельных сервисов)
  - Межсетевые экраны (граница сети)
  - DMZ

DRP (Disaster Recovery Plan) План восстановления инфраструктуры

- Разработка плана восстановления инфраструктуры
  - Периодичность
    - Актуализация по запросу (например, после обновления ПО или миграции на другое тех. решение)
    - Актуализация 1-2 раза в год
  - Утверждение профильными специалистами
  - Определение приоритетов для бизнеса
    - Проблема с сервисами, связанная с остановкой производственных процессов
    - Проблема с сервисами, связанная с крупными финансовыми потерями
    - Проблема с сервисами, связанная с репутационными рисками
    - Проблема с сервисами, связанная с угрозой для жизни (КИИ)
    - [Включает предыдущие риски] Кибератаки
    - Определение допустимого расчетного времени для восстановления сервисов (если время восстановления сервисов является недопустимым для типовых сценариев аварий, нужно либо менять требования, либо уменьшать время восстановления)
  - Определение наиболее приоритетных сценариев аварий
  - Разработка и утверждение плана восстановление инфраструктуры
- Обучение сотрудников
  - Разработка учебных материалов
  - Периодичность
    - При трудоустройстве (упрощенная программа)
    - Ежегодная
- DiRT (Disaster Recovery Testing) Проведение учений
  - Периодичность
    - Ежегодная
  - Определение наиболее приоритетных сценариев аварий (для DiRT)
  - Разработка отчета (postmortem)

Работа с персоналом ИТ/ИБ

- Собрания департамента (начальники отделов)
  - Периодичность
    - Еженедельные
    - Ежеквартальные
  - Определение повестки, подготовка
- Разделение зон ответственности подразделений компании
  - Обсуждение задач в зонах ответственности и нахождение решения (либо публичный отказ от решения)
- Собрания отдела (руководители групп)
  - Периодичность
    - Еженедельные
  - Определение повестки, подготовка
- Встречи 1 to 1
  - Ежемесячные либо ежеквартальные
- Удержание персонала
  - Разработка планов реагирования (включая возможные предложения по удержанию) при увольнении ключевых сотрудников
- Обучение и повышение квалификации
  - Матрица компетенций
  - Внешнее обучение
    - Реестр курсов в сетевой папке
  - Внутреннее обучение/ Разработка собственных курсов
  - План развития
  - Скилл ревью
    - Периодичность
      - По необходимости
      - Полугодовые или ежегодные
    - Разработка и актуализация матрицы компетенций
- Выполнение KPI подразделений
  - Периодическая актуализация KPI
- Дежурства (on-call)
  - Формирование команды
  - Ежемесячная актуализация графика
- Прочие задачи

Оборудование

- Устранение уязвимостей
  - Ежемесячная
  - Ежеквартальная
  - Ежегодная
- Обновление микрокода (прошивки)
  - Ежеквартальная
  - Ежегодная (проектная)
- Мониторинг (в широком смысле)
  - Observability
- Обслуживание
  - ИТ-оборудование
  - Оборудование ЦОД, электрика, кондиционирование, противопожарная сигнализация и пр.
  - Отдельная подсеть для обслуживания оборудования (iLO, iDRAC, IBMC)
- Обновление парка оборудования (закупка нового)
  - План развития ИТ/ИБ
- IoT
  - Циклы, специфичные для IoT
  - Ответственный за ИБ в IoT
- Жизненный цикл оборудования
  - Периодичность
    - Ежегодная
  - Обеспечение выполнения требований ИБ (от регуляторов)
  - Актуализация жизненного цикла оборудования

Программное обеспечение

- Жизненный цикл ПО
  - Периодичность
    - Ежеквартальная
    - Ежегодная
  - Обеспечение требований регуляторных мер
  - Актуализация жизненного цикла ПО
- Лицензирование
  - Формирование политики
- Разработка ПО (если есть код ОКВЭД 62.01)
  - Циклы, специфичные для разработки ПО
  - DevSecOps
- Устранение уязвимостей (hardening)
  - Периодичность
    - Еженедельная
    - Ежемесячная
    - Ежеквартальная
    - Ежегодная
  - Классификация уязвимостей
    - Вектор атаки
    - Актуальность/востребованность сценария
    - По типам устройств/сервисов/протоколов
  - Поиск уязвимостей, их приоритезация, поиск способов устранения
    - Дорожная карта по устранению уязвимостей (например, интеллект-карта)
  - Приоритетность
    - Критическая — составление групп устройств
    - Высокая — составление групп устройств
    - Средняя — составление групп устройств
  - Другие меры по закрытию уязвимостей
  - Выполнение обновления ПО
- Обновление ПО
  - Периодичность
    - Ежемесячное (только пользовательское ПО)
    - Ежеквартальное (в т. ч. серверное ПО)
    - Полугодовое (в т. ч. серверное ПО)
  - Тестирование
    - Обновление ПО в тестовой среде
      - Приоритетность
        - Критическая — составление групп устройств
        - Высокая — составление групп устройств
        - Средняя — составление групп устройств
    - Отсутствие проблем с работоспособностью ПО
    - Согласование периода выполнения работ
    - Выполнение работ

Бизнес-процессы

- Производственные процессы (в зависимости от специфики бизнеса)
- Логистические процессы (в зависимости от специфики бизнеса)
- Бухгалтерские процессы (в зависимости от специфики бизнеса)
  - Оплата оборудования и лицензий ПО
  - Платежи за типовые услуги (ежемесячная оплата), в т. ч. ФОТ
- Процессы других приоритетных направлений (в зависимости от специфики бизнеса)
- Решение конфликтных ситуаций
- Отчетность по ИТ/ИБ
  - Аналитика
    - Определение ключевых метрик
    - Определение динамики ключевых метрик к предыдущим периодам
      - Включая анализ потребности в ёмкости для хранения данных
    - Разработка аналитической части (интерпретация динамики в причинно-следственные связи и предложение по оптимизации)
  - Периодичность
    - Еженедельная
    - Ежеквартальная
    - Ежегодная
- Инструкция по реагированию на инцидент ИБ (playbook)
  - Отражение кибератак
    - Проведение расследования (форензика)
    - Разработка отчета (postmortem)
  - Актуализация инструкции
    - Ежегодная
    - При необходимости
- Восстановление сервисов после сбоя
  - Разработка отчета (postmortem)
- Разработка и актуализация эксплуатационной документации
- План развития ИТ/ИБ
  - Периодичность
    - Ежегодная (горизонт планирования 1-5 лет)
    - Ежеквартальная актуализация плана развития текущего периода (появляется возможность оперативной оценки для внесения изменений)
  - Ежегодное бюджетирование
    - Запрос скидок при миграции на новое тех. решение
  - Рабочая группа
  - Формирование тех. политики, среднесрочное и долгосрочное развитие ИТ/ИБ
    - Формирование политики лицензирования
    - Обоснование потребности в закупке технической поддержки
    - Формирование политики по автоматизации ручных действий администраторов
  - Планирование проектов
    - Реализация проектов
- Анализ регуляторных требований к ИТ/ИБ
  - 17, 21, 117, 239 ФСТЭК и т. д.
  - Другие
- Управление рисками
  - Обсуждение и согласование с ключевыми представителями бизнеса
    - Определение недопустимых событий
  - Расчет соотношения стоимости снижения ИТ/ИБ рисков (закупка оборудования, ПО и т. д.) к потенциально потерянной прибыли и репутационным рискам
  - Разделение обязанностей (SoD)
- Аудит инфраструктуры (внутренний/внешний)
  - Периодичность
    - Ежегодная
  - Актуализация методики аудита
  - Разработка отчета
  - Актуализация списка активов (отдельный бизнес процесс для автоматического добавления сервисов в этот список)
  - Ежемесячная оценка MTTA/MTTR
- Актуализация типовых настроек сервисов (включая типовые настройки ИБ для hardening)
- Внутренние киберучения (зависит от размеров организации, свободных ресурсов и требований к уровню ИБ процессов)
  - Антифишинговые
  - Red Team
  - Тренировки на киберполигоне
  - Совещания с руководством
- Разработка ПО (если есть код ОКВЭД 62.01)
  - Циклы, специфичные для разработки ПО
  - DevSecOps
- Другие аспекты ИБ (физическая и др.)

Сервисные заявки

- Анализ предложений и добавление в план развития инфраструктуры
- Анализ динамики по метрикам
  - Предложение по оптимизации
- Выполнение заявок (в т. ч. операционные задачи обслуживания)
  - Типовые заявки
  - Заявки, связанные с нарушением функционирования сервисов
    - Разработка отчета (postmortem)
  - SLI/SLO/SLA
  - Текущие задачи по обслуживанию инфраструктуры

Существующие сервисы

- ИБ сервисы
  - Влияющие на работоспособность производственных сервисов
    - Антивирусная защита
    - DLP
    - MFA
    - Antiphishing
    - WAF
    - IdM
    - NGFW, IDS/IPS
    - PAM
    - EDR
    - Sandbox
    - Другие
  - Не влияющие на работоспособность производственных сервисов (только информирование об инцидентах)
    - NTA
    - SIEM
    - SOAR
    - L3/L4 Filtering
    - Безопасное хранилище паролей
    - Управление уязвимостями (Vulnerability Management)
    - SGRC
    - XDR
    - Другие
  - Сервисы, которые скоро добавятся в эксплуатацию
  - Мониторинг (в широком смысле)
    - Устранение несоответствий в настройках сервисов
    - Observability
- ИТ сервисы
  - Инфраструктурные
    - Служба каталогов
    - Почта
    - Виртуализация
    - Резервное копирование
      - Проработка дополнительного уровня безопасности для резервного копирования (в т. ч. хранилище "судного дня")
      - Проверка работоспособности сервиса, проверка восстановления резервных копий
        - Формирование команды
        - Ежемесячная актуализация графика
    - Сеть/VPN
      - NetFlow
    - Wi-Fi
  - Прикладные
    - 1С, CRM
    - Проведение расчетов, клиент-банк
    - Терминальная ферма
    - Перечисление сервисов
  - Доступ для подрядчиков
  - Мониторинг (в широком смысле)
    - Устранение несоответствий в настройках сервисов
    - Observability
  - АСУ ТП
    - Перечисление сервисов
    - Перечисление сервисов
  - Облачные сервисы
  - Список ИТ сервисов организации
    - Dashboard
  - Сервисы, которые скоро добавятся в эксплуатацию
- Интеграция с внешними сервисами
  - Перечисление сервисов
  - Перечисление сервисов
- Сервисы на аутсорсинге
- Другие
  - Перечисление сервисов
  - Перечисление сервисов
- SLI/SLO/SLA
  - Определить целевые значения (и способ расчета SLO)
  - Унифицированный способ расчета SLI (при проблемах в сторонних сервисах)

Observability (общий подход в организации)

- Отказоустойчивый мониторинг
- Единая точка отказа
- Сбор и обработка метрик - хранение 7 дней, полезные метрики - хранение 90-365 дней

[Верхнеуровневый бизнес-процесс] Планирование непрерывности бизнеса (BCP)

Системная работа по снижению влияния рисков на работу организации

Разработка отчета (postmortem)

Бизнес-процесс по управлению рисками

Бизнес-процесс по аудиту инфраструктуры

План развития

Потенциальный риск кибератаки

Потенциальный риск кибератаки

Сеть Интернет

Presented with xmind